// MLSECOPSHUB · READINESS CHECKLIST

Cyber Resilience Act security checklist

Framework: Cyber Resilience Act (Regulation (EU) 2024/2847)
Official source: https://eur-lex.europa.eu/eli/reg/2024/2847/oj
Online version and control mapping: https://mlsecopshub.com/readiness/cyber-resilience-act
Last updated 2026-09-08. 28 items. Obligations are paraphrased; engineering guidance, not legal advice.

Scope and classification

- [ ] List every product with digital elements you place on the EU market, including SaaS components delivered as software and internal tools you distribute.
- [ ] Identify every ML model, AI agent, plugin and MCP server inside each product and record it as a component.
- [ ] Determine whether the product is default, important class I, important class II or critical under Annex III and IV.
- [ ] Record your role for each product: manufacturer, importer, distributor or open-source steward.
- [ ] Set the support period for each product and each model version, and document the reasoning.

Secure by design and by default

- [ ] Write a cybersecurity risk assessment that names AI-specific threats: unsafe deserialization, model poisoning, prompt injection, tool abuse.
- [ ] Make Safetensors, ONNX or GGUF the only accepted model formats in the build.
- [ ] Run PyTorch 2.6 or later patched for CVE-2025-32434 and keep weights_only=True as the only loader path.
- [ ] Ship agents and MCP servers with all tools denied by default and permissions declared in a manifest.
- [ ] Restrict agent network egress to an allowlist and remove unused tool integrations.
- [ ] Add a human confirmation gate for agent actions that change access, move money or send messages externally.
- [ ] Sandbox model inference and tool execution with least privilege.

Supply chain and SBOM

- [ ] Generate a CycloneDX or SPDX SBOM per release and extend it with models, datasets and inference runtimes.
- [ ] Sign every model artifact at build time and verify signatures at load time.
- [ ] Record provenance for third-party models: hub, repository, commit, hash, license and scan result.
- [ ] Quarantine and scan any model downloaded from a public hub before it enters the registry.
- [ ] Pin prompt templates and tool manifests by hash and treat changes as releases.

Vulnerability handling

- [ ] Publish a coordinated vulnerability disclosure policy that explicitly covers model and prompt-injection findings.
- [ ] Add a security.txt file with a working contact address.
- [ ] Define a triage SLA for AI-class reports and a process for replacing a model version securely.
- [ ] Publish advisories when a model or prompt template is replaced for a security reason.
- [ ] Deliver security updates for models through the same signed update channel as code.
- [ ] Test rollback of a model version in staging at least quarterly.

Reporting and monitoring

- [ ] Map AI-specific incidents (malicious model in the supply chain, injection exploited in the field) to Article 14 triggers.
- [ ] Prepare templates for the 24-hour early warning, 72-hour notification and 14-day final report.
- [ ]

Ensure an on-call role can file a notification on the ENISA single reporting platform within 24 hours.

- [ ] Log model version, prompt version and tool calls for every inference, with tamper-evident storage.
- [ ] Run a tabletop exercise for a compromised model artifact scenario before 11 September 2026.

```
Have this run against your pipeline: https://mlsecopshub.com/services
Book a 30-minute assessment call: https://mlsecopshub.com/contact
```